Saudi GRC Platform

Developer Handoff

Source: `developer-handoff.md`

14 — Developer Handoff Specification

Everything a developer joining the platform needs to be productive on day one. Anchored to the actual code at HEAD.

---

1. Platform assumptions

- Single SQL Server database per tenant; multi-tenant logical isolation via `organisationId` on every row.
- Java 17 (pinned — Lombok incompatible with Java 25 in this repo).
- Spring Boot 3.5 + Hibernate 6 + Spring Security 6.
- React 18 + Vite 5 + TypeScript (strict). No SSR.
- Backend port 8084 (dev); frontend dev server 5173 (proxies `/api` and `/ws` to 8084).
- Hard rules: never disable hooks, never commit secrets, never run `mvn flyway:clean`.

2. Recommended architecture

Layer	Choice	Why
Backend	Spring Boot modular monolith	one repo, one process, fast iteration; modules under module/
ORM	Hibernate 6 / Spring Data JPA	familiar; @Where for soft-delete
API	REST JSON over HTTPS; STOMP/WebSocket for realtime	broad client compat
DB	SQL Server 2019+ with UTF-8 collation	KSA-common; collation Latin1_General_100_CI_AS_SC_UTF8
Migrations	Flyway (non-dev profiles); Python bootstrap scripts (dev)	controlled prod; flexible dev
Caching	Caffeine L1	adequate for current scale
Background work	@Scheduled + @Async	simple; Spring TaskExecutor
Frontend	Vite + React 18 + TanStack Query (via shared lib/api.ts)	fast HMR; SSR-not-needed
Charts	Chart.js 4 + custom 3D bars	bilingual + RTL-aware
PDF	OpenPDF 1.3 + RTL font config	Arabic shaping support
XLSX	Apache POI 5.2	full-featured
Auth	JJWT 0.12.6 (HS256 access, HttpOnly refresh cookie)	stateless + safe
Observability	Actuator + JSON logs + Micrometer	standard

3. Workflow engine requirements

- Each module owns its state machine in its `service/` class.
- Transition methods throw `IllegalTransitionException` (HTTP 409) on forbidden moves.
- Every transition: (a) writes to audit, (b) broadcasts via `RealtimeBroadcaster`, (c) calls automation hooks.

- Workflow versions live in `workflow.workflow_versions`; in-flight records keep their start-version snapshot.

4. API requirements

- All endpoints under `/api/...`.
- OpenAPI 3 at `/v3/api-docs`, Swagger UI at `/swagger-ui.html` (dev only).
- Standard responses: 200 (ok), 201 (created), 204 (no-content), 400 (validation), 401 (unauth), 403 (forbidden), 404 (not-found), 409 (illegal transition), 500 (with problem-detail JSON).
- Pagination: `?page=&size=` returning Spring `Page` JSON.
- Filtering: query params per resource; complex via filter modal payload.
- Sorting: `?sort=field,asc|desc`.
- Bilingual: every entity returns `*_en` + `*_ar`; client picks.
- CORS: dev allowlist in `application-dev.yml`; prod via Ingress.

5. Database requirements

- Soft-delete: every business table has `is_deleted SMALLINT DEFAULT 0`; every JPA entity has `@Where(clause = "is_deleted = 0")`.
- Tenancy: every business table has `organisation_id BIGINT NOT NULL`; indexed first in any composite index.
- Audit columns: `created_at`, `created_by`, `updated_at`, `updated_by`, `deleted_at`, `deleted_by`, `row_version`.
- Bilingual: `*_en NVARCHAR(N) NOT NULL`, `*_ar NVARCHAR(N) NULL` (AR recommended but not required).
- Foreign keys: indexed on both sides; cascade behaviour explicit.
- Migrations: Flyway, V*-numbered, idempotent (`IF NOT EXISTS` guards).
- Encoding: SQL files saved as UTF-8 with BOM; Flyway `encoding=UTF-8` in `application.yml`.

6. Audit-trail requirements

- Every state transition writes to `audit.events`.
- Sensitive reads (auditor view, PII access) also write read-events.
- `audit.events` retention: 60 months minimum.
- Only roles with `AUDIT_READ` permission can query.
- Tamper-evidence: optional periodic chain hash of `audit.events` blocks (planned).

7. Notification requirements

- All notifications flow through `notification.outbox`.
- Per-recipient channel preferences in `notification.channels`.
- Channels supported: EMAIL (SMTP), SMS (placeholder for Saudi gateway), WEBHOOK (HMAC signed), MS Teams (webhook).

- Outbox processor: `@Scheduled(fixedDelay)`; at-least-once with idempotency key.

8. Integration requirements

- Inbound: REST + scheduled fetchers + webhook receivers (intake module).
- Outbound: webhook to vendors / regulators / connected systems.
- File exchange: SFTP (planned) for regulator filings.
- Federation: SSO/SAML2 + OIDC; Saudi-specific Nafath integration via `module/iam/sso/`.
- Connectors directory: `tss-grc-backend/src/main/java/com/tss/grc/module/intake/connectors/`.

9. Digital signature requirements

- Generic transaction model (`signature.digital_signature_transactions`) with `provider` field.
- Providers: INTERNAL (HS256 hash), DOCUSIGN, ABSHER, NAFATH, custom.
- Provider-specific adapters under `module/signature/provider/`.
- Bind signature to a SHA-256 digest of the payload at sign-time so the signer can't repudiate by changing the underlying record.
- MFA must be within 15 minutes of the sign action.

10. Security requirements

- TLS 1.2+ at edge; backend HTTP only on local interface.
- JWT secret rotation: at least quarterly (deploy-pipeline-managed env var).
- Password policy: min 12 chars, complexity, no top-1000 list, history 12.
- MFA: TOTP default; SMS as fallback; WebAuthn (planned).
- Brute-force: 5 fails → 15-min lockout (prod); 99 fails → 1-min in dev.
- CSP: strict; Swagger UI exempted in dev only.
- DB at rest: TDE + per-blob AES-256.
- Backups: encrypted, off-site, restore-tested quarterly.

11. Localization requirements

- Two languages: ar-SA (primary), en (secondary).
- Calendar: dual surface (Gregorian + Hijri) for user-facing dates.
- Number formats: Arabic-Indic digits optional per user pref; ISO-8601 internally.
- Currency: SAR primary; multi-currency where business-meaningful.
- RTL CSS: logical properties (`margin-inline-start`, `padding-inline-end`) throughout — no `left`/`right`.
- PDF/PPTX rendering: dedicated `RtlFontConfig` with shaping-aware Arabic font stack.

12. Reporting requirements

- Bilingual report templates (one definition, two render passes).

- Export pipeline: queueable for >5s reports; live for snapshot.
- Watermarking: classification stamp on every export.
- Audit: every export writes `audit.events` (verb=export).
- Board pack: signed (Chairman); distributed only after sign.

13. Testing requirements

- Backend: 272+ JUnit/Spring tests at HEAD; minimum 70% line coverage on service layer.
- Frontend: TypeScript strict; per-page smoke test with `mcp__Claude_Preview__preview` during dev.
- Integration: Postman/Bruno collection mirroring OpenAPI.
- UAT: per the test-case catalogue in `/14-Test-Cases/`.
- Performance: page LCP < 2s on cold load (target).

14. Data migration requirements

- Greenfield: Flyway V1..VN bootstraps everything; dev uses Python scripts (`setup_*.py`) for speed.
- Brownfield (customer-import):
- One-off ETL into `migration_staging.*` tables.
- Then `INSERT INTO module.* SELECT ... FROM migration_staging.*`.
- Mark all imported rows with `external_id` containing the source system identifier.
- Mojibake fix: `fix_arabic_mojibake.py` runs after any non-UTF-8 import to repair encoded Arabic.

Repo layout cheat sheet

```
/
■■■ tss-grc-backend/ ← Spring Boot REST API
■ ■■■ src/main/java/com/tss/grc/
■ ■■■ GrcApplication.java
■ ■■■ config/ ← Security, Cors, DataSource, Cache, OpenApi, Locale, WebMvc
■ ■■■ security/ ← JwtTokenProvider, JwtAuthenticationFilter, GrcUserDetails,
ModulePermissionEvaluator
■ ■■■ common/ ← BaseEntity, tenant/, exception/, model/
■ ■■■ module/ ← 17 functional modules
■ ■■■ auth, iam, admin, risk, bcm, scm, tprm, cyber,
■ ■■■ compliance, privacy, evidence, incident, capa,
■ ■■■ signature, workflow, reporting, dashboard, platform
■■■ tss-grc-ui-v2/ ← Frontend
■ ■■■ src/
■ ■■■ App.tsx
■ ■■■ lib/ ← api.ts, auth.ts, i18n.tsx, toast.tsx, ...
■ ■■■ components/ ← layout/, ui/, viz/, ...
■ ■■■ pages/ ← one folder per route
■ ■■■ translations/ ← en.ts + ar.ts
■■■ tss-grc-backend/src/main/resources/
■ ■■■ application.yml + application-dev.yml + application-prod.yml
```

```
■ ■■■ messages*.properties ← server i18n
■ ■■■ db/migration/sqlserver/ ← Flyway V*
■■■ Saudi-GRC-Platform-Integration/ ← this deliverable package
■■■ docs/ ← internal docs
```

Onboarding checklist

- [ ] Clone repo
- [ ] Install JDK 17, Maven, Node 20, SQL Server 2019
- [ ] Create DB `TSS_GRC` with `Latin1_General_100_CI_AS_SC_UTF8`
- [ ] Run Python bootstrap scripts (`setup_cyber_db.py`, `setup_bcm_db.py`, `fix_arabic_db.py`)
- [ ] Set env `JWT_SECRET`, `DB_USERNAME`, `DB_PASSWORD`
- [ ] `mvn spring-boot:run -Dspring-boot.run.profiles=dev`
- [ ] `cd tss-grc-ui-v2 && npm install && npm run dev`
- [ ] Login `admin / Admin@12345` at `http://localhost:5173`